T.C.
İSTANBUL BEYKENT ÜNİVERSİTESİ
BİLGİSAYAR TEKNOLOJİLERİ BÖLÜMÜ
BİLGİSAYAR PROGRAMCILIĞI

SİBER GÜVENLİĞİN TEMELLERİ
FİNAL PROJE RAPORU

Kriptografi Algoritmaları, Saldırı Teknikleri
ve Savunma Yöntemleri Üzerine Bir İnceleme

Hazırlayan
Efe Osmanhan Güdücü

Dersi Veren Öğretim Görevlileri
Öğr. Gör. Anıl YILDIZ
Öğr. Gör. Burcu GÜLDÜREN FİDANCI

İstanbul, 2026

İÇİNDEKİLER

GİRİŞ.....1
1. SEZAR ŞİFRELEME ALGORİTMASI.....1
2. VİGENERE ŞİFRELEME ALGORİTMASI.....2
3. MD5 HASH ALGORİTMASI.....3
4. RSA ŞİFRELEME ALGORİTMASI.....4
5. BASE64 KODLAMA YÖNTEMİ.....5
6. SANAL MAKİNE VE KALİ LİNUX KURULUMU.....5
7. DDoS SALDIRISI.....6
8. ZAFİYET TARAMASI.....7
9. SQL INJECTION.....8
10. DEEP WEB VE TOR AĞI.....8
SONUÇ.....9
KAYNAKÇA.....10

GİRİŞ

Dijital dönüşümün hızlandığı günümüzde, bireysel kullanıcılardan büyük kurumsal yapılara kadar her aktör için siber güvenlik artık opsiyonel değil, zorunlu bir disiplin haline gelmiştir. Bankacılık işlemlerinden iletişime, sağlık verilerinden ulusal altyapılara kadar yaşamın her alanı dijital ortamda yürütülmekte; bu da beraberinde ciddi güvenlik tehditlerini getirmektedir. Yapılan araştırmalar, dünya genelinde her gün milyonlarca siber saldırı denemesinin gerçekleştiğini ve bu rakamın her geçen yıl katlanarak arttığını ortaya koymaktadır.

Siber güvenlik alanı; kriptografi, ağ güvenliği, uygulama güvenliği, sosyal mühendislik ve adli analiz gibi pek çok alt dalı içermektedir. Bu çalışma kapsamında, alanın temel taşlarını oluşturan on farklı konu ele alınmıştır. Çalışma, antik dönem şifreleme tekniklerinden başlayarak günümüzün modern asimetrik algoritmalarına, oradan da gerçek dünya saldırı senaryolarına uzanan kronolojik ve kavramsal bir çerçeve sunmaktadır.

Raporun ilk yarısı kriptografi temellerine ayrılmış; Sezar ve Vigenere gibi klasik yöntemler, MD5 gibi hash fonksiyonları, RSA gibi asimetrik şifreleme algoritmaları ve şifreleme ile sıkça karıştırılan Base64 kodlama yöntemi incelenmiştir. İkinci yarıda ise penetrasyon testi ortamı olan Kali Linux kurulumu, ağ tabanlı DDoS saldırıları, zafiyet tarama metodolojisi, web uygulamalarına yönelik SQL Injection ve son olarak Deep Web ile Tor ağı kavramları açıklanmıştır. Her başlık, hem teorik temelleriyle hem de pratik örnekleriyle ele alınmıştır.

1. SEZAR ŞİFRELEME ALGORİTMASI

Sezar şifrelemesi, kriptografi tarihinin bilinen en eski şifreleme yöntemlerinden biridir. İsmini, M.Ö. 1. yüzyılda yaşamış olan Roma İmparatoru Julius Caesar'dan almaktadır. Sezar'ın askeri komutanlarına gönderdiği gizli yazışmalarda bu yöntemi kullandığı tarihsel kayıtlarda yer almaktadır. Algoritma, monoalfabetik ikame (substitution) şifreleme sınıfına dahildir.

Sezar şifrelemesinin çalışma prensibi son derece basittir. Açık metindeki her harf, alfabe üzerinde belirli bir sayı kadar kaydırılarak şifrelenir. Bu kaydırma miktarına anahtar (k) adı verilmektedir. Matematiksel olarak ifade edilirse, şifreli harfin değeri, açık harfin sayısal karşılığı ile anahtarın toplamının 26 modülüne eşittir ($c = (m + k) \bmod 26$). 26 modülünün kullanılma nedeni, kaydırma işleminin alfabe sınırını aşması durumunda baştan devam etmesini sağlamaktır.

Algoritmanın çalışmasını somutlaştırmak için basit bir örnek verilebilir. Anahtar değeri 3 olarak seçildiğinde, "EVET" kelimesi şifrelendiğinde aşağıdaki dönüşüm gerçekleşir: E harfi H'ye, V harfi Y'ye, E harfi tekrar H'ye ve T harfi W'ye dönüşmektedir. Sonuç olarak şifreli metin "HYHW" halini almaktadır. Şifrenin çözümü için aynı anahtarın ters yönde uygulanması yeterlidir.

Sezar şifrelemesinin günümüz koşullarında güvenli kabul edilebilmesi mümkün değildir. Bunun başlıca iki nedeni bulunmaktadır. Birincisi, algoritmada yalnızca 25 farklı anlamlı anahtar bulunmaktadır; modern bir bilgisayar bu olasılıkların tamamını saniyenin çok altında deneyerek kırabilmektedir (brute-force saldırısı). İkincisi, doğal dillerdeki harf frekanslarının istatistiksel

özelliklerinden yararlanan frekans analizi yöntemi ile şifre kolayca çözülebilmektedir. Örneğin Türkçe'de "a" ve "e" harfleri yüksek frekansla görülmekte olup, şifreli metindeki en sık geçen harf bu harflerle eşleştirildiğinde anahtar tespit edilebilmektedir.

Tüm bu zayıflıklara rağmen Sezar şifrelemesi, eğitsel ve tarihsel açıdan büyük önem taşımaktadır. Modern kriptografi disiplininin temel kavramları olan açık metin, şifreli metin, anahtar ve algoritma kavramları en sade haliyle bu yöntemde gözlemlenebilmektedir.

2. VİGENERE ŞİFRELEME ALGORİTMASI

Vigenere şifrelemesi, 16. yüzyılda Fransız diplomat Blaise de Vigenere tarafından geliştirilen ve polialfabetik ikame sınıfına dahil olan bir şifreleme yöntemidir. Sezar şifrelemesinin daha gelişmiş bir versiyonu olarak kabul edilebilecek bu yöntem, geliştirildiği dönemden 19. yüzyıla kadar yaklaşık üç asır boyunca kırılması mümkün olmayan bir algoritma olarak tanınmıştır. Bu nedenle dönemin literatüründe "Le Chiffre Indéchiffrable" (Çözülemez Şifre) olarak adlandırılmıştır.

Sezar şifrelemesinde sabit bir sayısal anahtar kullanılırken, Vigenere yönteminde bir anahtar kelime kullanılmaktadır. Anahtar kelimedeki her harf, alfabe üzerindeki konumuna karşılık gelen bir kaydırma değeri belirler. Şifrelenecek metnin her harfine, anahtar kelimenin sırayla tekrarlanan harflerinin belirlediği farklı kaydırma değerleri uygulanır.

Algoritmanın işleyişini örneklendirmek için anahtar kelimenin "KEDİ" olduğunu varsayalım. Bu durumda K harfi 10, E harfi 4, D harfi 3 ve İ harfi 9 değerlerine karşılık gelir. Şifrelenmek istenen metnin ilk harfi 10, ikincisi 4, üçüncüsü 3, dördüncüsü ise 9 birim kaydırılır. Anahtar kelimenin uzunluğu metin boyunca yetmediğinde, anahtar baştan tekrarlanarak uygulanır.

Vigenere şifrelemesinin Sezar yöntemine karşı en büyük üstünlüğü, frekans analizine doğrudan dayanıklı olmasıdır. Sezar'da açık metindeki bir harf her zaman aynı şifreli harfe dönüşürken, Vigenere yönteminde aynı harf anahtar kelimenin farklı pozisyonlarına denk geldiğinde farklı şifreli harflere dönüşebilmektedir. Bu durum, dile özgü harf frekanslarının şifreli metinde dağılarak istatistiksel olarak silikleşmesini sağlamaktadır.

Bununla birlikte Vigenere şifrelemesi de mutlak güvenli değildir. 19. yüzyılda Friedrich Kasiski tarafından geliştirilen ve günümüzde "Kasiski testi" olarak bilinen yöntem, şifreli metindeki tekrarlayan harf gruplarının arasındaki mesafenin anahtar uzunluğunun katları olduğu prensibine dayanmaktadır. Anahtar uzunluğunun tespiti sonrasında metin sütunlara bölünmekte ve her sütun bağımsız bir Sezar şifresi olarak çözülmektedir.

Vigenere şifrelemesinin tarihteki en büyük katkısı, polialfabetik şifreleme fikrini kriptografi dünyasına kazandırmasıdır. Aynı düz metin sembolünün farklı şifreli sembollere dönüşebilmesi prensibi, günümüz blok şifreleme algoritmalarının (örneğin AES) temelinde yatan kavramlardan biridir.

3. MD5 HASH ALGORİTMASI

MD5 (Message-Digest Algorithm 5), 1991 yılında Ronald Rivest tarafından geliştirilen kriptografik bir hash fonksiyonudur. Burada öncelikle önemli bir kavram ayrımı yapılması gerekmektedir: MD5 bir şifreleme algoritması değil, bir hash algoritmasıdır. Şifreleme iki yönlü bir işlem olup açık metnin tekrar elde edilmesini mümkün kılarken, hash fonksiyonu tek yönlüdür ve elde edilen özet değerinden orijinal veriye geri dönüş matematiksel olarak mümkün değildir. Bu özelliğe literatürde "tek yönlü fonksiyon" (one-way function) adı verilmektedir.

MD5 algoritması, herhangi bir uzunluktaki giriş verisini alarak sabit 128 bit (32 karakterlik hexadecimal değer) bir çıktı üretmektedir. Bu çıktıya "mesaj özeti" veya "hash değeri" denilmektedir. Algoritmanın belirleyici özelliklerinden biri, deterministik olmasıdır; yani aynı girdi her zaman aynı çıktıyı üretir. Bir diğer önemli özelliği ise "çığ etkisi" (avalanche effect) olarak adlandırılan davranıştır. Giriş verisindeki en küçük bir değişiklik dahi çıktı değerinin tamamen farklı görünmesine yol açmaktadır. Örneğin "merhaba" kelimesinin MD5 değeri ile sadece son harfi değiştirilmiş "merhabb" kelimesinin MD5 değerleri arasında hiçbir görsel benzerlik bulunmamaktadır.

MD5 algoritması tarihsel olarak çeşitli alanlarda yaygın biçimde kullanılmıştır. Bunların başında dosya bütünlüğünün doğrulanması gelmektedir; özellikle işletim sistemi ISO görüntüleri veya büyük yazılım dağıtımları indirildiğinde, dağıtıcı kurum tarafından yayınlanan MD5 değeri ile kullanıcının hesapladığı değer karşılaştırılarak dosyanın bozulup bozulmadığı kontrol edilmektedir. Bunun yanı sıra eski dönem parola saklama sistemlerinde, dijital imzalarda ve veri tabanı entegrasyonunda da kullanılmıştır.

Ne var ki MD5 günümüzde güvenli kabul edilmemektedir. 2004 yılında Çinli kriptograf Xiaoyun Wang ve ekibinin yayınladığı çalışmada, farklı iki girdinin aynı MD5 özet değerini üretebileceği matematiksel olarak gösterilmiştir (Wang & Yu, 2005). Bu duruma "çakışma saldırısı" (collision attack) adı verilmektedir. Pratikte bu zafiyet, kötü niyetli bir saldırganın meşru bir dosyayla aynı MD5 değerine sahip zararlı bir dosya üretebilmesine olanak tanımaktadır. Bu nedenle güvenlik kritik uygulamalarda MD5'in yerini SHA-256 ve SHA-3 gibi daha güçlü algoritmalar almıştır.

4. RSA ŞİFRELEME ALGORİTMASI

RSA algoritması, 1977 yılında Ron Rivest, Adi Shamir ve Leonard Adleman tarafından geliştirilmiş asimetrik bir şifreleme algoritmasıdır. Algoritmanın ismi, geliştiricilerinin soyadlarının baş harflerinden türetilmiştir. RSA, modern internet altyapısının güvenlik temelini oluşturan en önemli algoritmalardan biri olarak kabul edilmekte; bankacılık işlemlerinden anlık mesajlaşma uygulamalarına, dijital imzalardan SSL/TLS sertifikalarına kadar geniş bir yelpazede aktif olarak kullanılmaktadır.

Daha önce incelenen Sezar ve Vigenere algoritmaları simetrik şifreleme sınıfına dahildir; yani aynı anahtar hem şifreleme hem de çözme işleminde kullanılmaktadır. Bu durum, "anahtar dağıtım problemi" adı verilen önemli bir güvenlik açığını beraberinde getirmektedir. Şifreli iletişim kurmak

isteyen iki taraf, anahtarı güvenli olmayan bir kanal üzerinden paylaşmak zorunda kaldığında, anahtarın yetkisiz kişilerin eline geçmesi şifrelemenin değerini ortadan kaldırmaktadır.

RSA, bu problemi çift anahtarlı yapısıyla çözmektedir. Sistemde iki adet matematiksel olarak ilişkili fakat birbirinden türetilmesi pratik olarak imkânsız anahtar bulunmaktadır: kullanıcının herkesle paylaşabildiği "genel anahtar" (public key) ve sadece kullanıcıda kalan "özel anahtar" (private key). Bir tarafın gönderdiği mesaj, alıcının genel anahtarı ile şifrelenmekte; bu şifreli mesaj yalnızca alıcının özel anahtarıyla çözülebilmektedir. Şifreleyen kişi dahi kendi gönderdiği mesajı çözememektedir.

Algoritmanın matematiksel güvenliği, büyük asal sayıların çarpanlarına ayrılmasının zorluğu prensibine dayanmaktadır. Anahtar üretimi sırasında p ve q olarak adlandırılan iki çok büyük asal sayı seçilir ve bu sayıların çarpımı ($n = p \times q$) genel anahtarın bir parçası olarak ilan edilir. Mevcut bilgisayar teknolojisi ile 2048 bit uzunluğundaki bir RSA anahtarının çarpanlarına ayrılması milyarlarca yıl alacağı için sistem güvenli kabul edilmektedir.

RSA günümüzde HTTPS protokolünün omurgasında yer almakta; tarayıcı adres çubuğundaki kilit simgesinin arkasında çalışan kriptografik altyapı RSA veya benzeri asimetrik algoritmalar tarafından sağlanmaktadır. Bunun yanı sıra dijital imzalar, e-imza altyapısı ve uçtan uca şifreleme protokolleri de RSA temelli çözümler kullanmaktadır.

5. BASE64 KODLAMA YÖNTEMİ

Base64, ikili (binary) verileri ASCII metnine dönüştürmek için kullanılan bir kodlama yöntemidir. Burada da önemli bir kavram ayrımının altı çizilmelidir: Base64 bir şifreleme algoritması değildir, bir kodlama (encoding) yöntemidir. Şifreleme gizlilik amacıyla yapılır ve anahtar gerektirir; kodlama ise verinin formatını değiştirmek amacıyla yapılır, anahtar gerektirmez ve herkes tarafından geri çözülebilir.

Base64 yönteminin ortaya çıkmasının tarihsel nedeni, eski iletişim protokollerinin yalnızca yazdırılabilir ASCII karakterlerini güvenli biçimde taşıyabilmesidir. Özellikle erken dönem e-posta protokolleri olan SMTP, ikili verileri doğrudan iletmede sorun yaşamaktaydı. Bu nedenle resim, ses ve video gibi ikili verilerin metne dönüştürülmesi ihtiyacı doğmuş; Base64 bu ihtiyacın yanıtı olarak standartlaşmıştır.

Yöntemin ismindeki "64" sayısı, kullanılan karakter sayısını ifade etmektedir. Base64 alfabesi 64 farklı karakterden oluşur: A'dan Z'ye 26 büyük harf, a'dan z'ye 26 küçük harf, 0'dan 9'a 10 rakam, artı işareti (+) ve bölü çizgisi (/). Algoritma, ikili veriyi üçer baytlık (24 bit) gruplara böler ve her grubu dörder altı bitlik parçaya ayırır. Her altı bitlik değer (0-63) Base64 alfabesinde karşılık geldiği karaktere eşlenir.

Base64 kodlamasının günümüzdeki kullanım alanları oldukça çeşitlidir. E-posta eklerinin MIME protokolü altında taşınması, HTML belgelerinde inline (satır içi) görsel gömme

(…), API çağrılarında Basic Authentication başlığının oluşturulması ve JSON Web Token (JWT) yapısının payload kısmının taşınması en yaygın kullanım örnekleridir.

Son olarak vurgulanması gereken kritik bir nokta vardır: Base64 ile kodlanmış bir veri kesinlikle şifrelenmiş kabul edilemez. Herhangi bir kullanıcı, çevrimiçi araçlar veya basit kod satırlarıyla Base64 ile kodlanmış veriyi saniyeler içinde geri çözebilir. Bu nedenle hassas verilerin Base64'e dönüştürülerek saklanması veya iletilmesi yaygın ancak yanlış bir güvenlik uygulamasıdır.

6. SANAL MAKİNE VE KALİ LİNUX KURULUMU

Kali Linux, Offensive Security firması tarafından geliştirilen ve sızma testi (penetration testing) ile siber güvenlik araştırmaları için özel olarak tasarlanmış, Debian tabanlı bir Linux dağıtımıdır. İçeriğinde 600'ün üzerinde önyüklenmiş güvenlik aracı barındırmakta; Nmap, Metasploit Framework, Wireshark, Burp Suite, John the Ripper ve Aircrack-ng gibi endüstri standardı araçlar dağıtımla birlikte hazır olarak gelmektedir.

Kali Linux'un sanal makine üzerinde kurulması, ana sistemin güvenliği ve kullanım esnekliği açısından önerilen yaklaşımdır. Sanal makine yaklaşımının başlıca üç avantajı bulunmaktadır. Birincisi, izolasyondur; Kali üzerinde gerçekleştirilen testler ana işletim sistemini hiçbir şekilde etkilememektedir. İkincisi, anlık görüntü (snapshot) alma özelliği sayesinde sistemin temiz haline istenildiği anda dönülebilmesidir. Üçüncüsü, test ortamlarının üretim ortamından ağ düzeyinde ayrılabilmesidir.

Sanal makine yazılımı olarak iki popüler tercih bulunmaktadır: Oracle tarafından geliştirilen açık kaynaklı ve ücretsiz Oracle VM VirtualBox ile VMware Workstation Player. Bu çalışma kapsamında VirtualBox tercih edilmiştir.

Kurulum süreci aşağıdaki adımlardan oluşmaktadır. Öncelikle resmi kali.org adresinden hazır VirtualBox disk imajı (.vbox veya .ova formatında) indirilmektedir. İndirilen dosyanın doğrulanması için yayınlanan SHA-256 hash değeri kontrol edilmektedir. Ardından VirtualBox üzerinde yeni bir sanal makine oluşturulmakta, RAM boyutu en az 4 GB (tercihen 6 GB) ve sanal disk alanı en az 20 GB olarak yapılandırılmaktadır. Ağ ayarları varsayılan NAT modunda bırakılarak internet erişimi sağlanmaktadır. İlk girişte varsayılan kullanıcı adı ve şifresi "kali" olarak ayarlanmıştır.

Kurulum sonrasında uygulanması gereken üç temel işlem vardır: sistem güncellemelerinin "sudo apt update && sudo apt upgrade -y" komutu ile yapılması, temiz sistemin snapshot olarak kaydedilmesi ve VirtualBox Guest Additions kurulumu ile ekran çözünürlüğü ve panodan veri aktarımı gibi özelliklerin aktif hale getirilmesidir.

Etik açıdan vurgulanması gereken önemli bir konu vardır. Kali Linux içerisindeki araçlar son derece güçlü olup yetkisiz kullanıldığında ciddi hukuki sonuçlar doğurabilir. Türkiye Cumhuriyeti yasaları çerçevesinde, Türk Ceza Kanunu'nun 243, 244 ve 245. maddeleri bilişim sistemlerine yetkisiz erişimi, sistemlerin işleyişini engellemeyi ve banka ya da kredi kartlarının kötüye

kullanılmasını suç olarak tanımlamakta ve hapis cezası öngörmektedir. Bu nedenle Kali Linux yalnızca kişiye ait sistemlerde veya yazılı izin alınmış test ortamlarında kullanılmalıdır.

7. DDoS SALDIRISI

DDoS (Distributed Denial of Service – Dağıtık Hizmet Engelleme), modern internetin karşı karşıya olduğu en yaygın ve en yıkıcı siber saldırı türlerinden biridir. Saldırının amacı, hedef sistemin meşru kullanıcılara hizmet vermesini engellemektir. Kavramsal olarak DoS (Denial of Service) saldırısının dağıtık versiyonudur; tek bir kaynaktan yapılan DoS saldırısının aksine, binlerce hatta yüz binlerce farklı kaynaktan eş zamanlı olarak gerçekleştirilir.

DDoS saldırılarında kullanılan dağıtık kaynaklar genellikle "botnet" olarak adlandırılan ele geçirilmiş cihaz ağlarından oluşmaktadır. Bu ağlar, zararlı yazılım yoluyla kontrol altına alınmış bilgisayarlar, akıllı televizyonlar, IP kameralar, yönlendiriciler ve diğer IoT (Nesnelerin İnterneti) cihazlarından meydana gelebilmektedir. Cihaz sahipleri çoğu zaman cihazlarının bir saldırıya katıldığından haberdar dahi olmamaktadır.

Tarihteki en büyük DDoS saldırılarından biri olarak 2016 yılında gerçekleştirilen Mirai botnet saldırısı gösterilebilir. Bu saldırıda yaklaşık 600 bin güvensiz IoT cihazı (özellikle varsayılan şifrelerle çalışan IP kameralar) ele geçirilerek Dyn DNS sağlayıcısına yönlendirilmiş; bu olay sonucunda Twitter, Netflix, Reddit, GitHub ve Spotify gibi büyük servisler saatlerce erişilemez hale gelmiştir.

DDoS saldırıları teknik açıdan üç ana kategoride sınıflandırılır. Birinci kategori hacim tabanlı saldırılardır; UDP flood ve ICMP flood gibi yöntemlerle hedefin bant genişliği doldurulmaya çalışılır. İkinci kategori protokol tabanlı saldırılardır; bunların en bilineni SYN flood saldırısıdır. Bu saldırıda TCP protokolünün üç yönlü el sıkışma mekanizması istismar edilir; saldırgan binlerce SYN paketi gönderir ancak el sıkışmayı tamamlamayarak sunucunun bağlantı kuyruğunu doldurur. Üçüncü kategori ise uygulama katmanı saldırılardır; HTTP flood ve Slowloris gibi teknikler kullanılarak meşru görünen ancak aşırı sayıdaki istekle web sunucusu meşgul edilir.

DDoS saldırılarına karşı geliştirilmiş çeşitli savunma mekanizmaları mevcuttur. IP başına istek sayısını sınırlandıran rate-limiting uygulamaları, saldırı imzalarını tanıyan güvenlik duvarı ve IDS/IPS sistemleri, trafik filtreleme altyapısı sunan CDN servisleri (Cloudflare, AWS Shield, Akamai) ve makine öğrenmesi tabanlı anomali tespit sistemleri başlıca savunma yaklaşımlarını oluşturmaktadır.

8. ZAFİYET TARAMASI

Zafiyet taraması (vulnerability scanning), bir bilişim sistemindeki bilinen güvenlik açıklarının sistematik biçimde tespit edilmesi sürecidir. Hem saldırı senaryolarının ön hazırlığı hem de savunma stratejilerinin oluşturulması açısından kritik bir adım olarak kabul edilmektedir. Zafiyet taraması ile penetrasyon testi (pentest) sıklıkla karıştırılmaktadır; ancak ikisi farklı kavramlardır. Zafiyet taraması

açıkların tespitine odaklanan otomatik bir süreç iken, penetrasyon testi tespit edilen açıkların aktif olarak istismar edilmesini içeren manuel bir süreçtir.

Zafiyet tarama süreci genellikle dört aşamada gerçekleştirilmektedir. İlk aşama, keşif (reconnaissance) olarak adlandırılan pasif bilgi toplama sürecidir. Bu aşamada hedef hakkında WHOIS sorguları, DNS kayıtları analizi ve Google dorking gibi tekniklerle bilgi toplanır. İkinci aşama, hedef sistem üzerindeki açık portların ve bu portlarda çalışan servislerin tespit edildiği port taraması aşamasıdır. Üçüncü aşama, servislerin sürüm bilgilerinin belirlendiği enumeration aşamasıdır. Dördüncü ve son aşama ise toplanan bilgilerin CVE (Common Vulnerabilities and Exposures) veri tabanı ile eşleştirilerek bilinen açıkların ortaya çıkarıldığı analiz aşamasıdır.

CVE sistemi, dünya genelindeki bilinen güvenlik açıklarının tek tip kimlikle kataloglanmasını sağlayan uluslararası bir standarttır. Her açığa benzersiz bir CVE numarası ve CVSS (Common Vulnerability Scoring System) puanı atanmaktadır. Örnek vermek gerekirse, 2021 yılı sonunda keşfedilen ve geniş yankı uyandıran Log4Shell zafiyeti CVE-2021-44228 koduyla kataloglanmış olup CVSS skoru 10 üzerinden 10 yani “kritik” seviyede belirlenmiştir. Bu açık, Java tabanlı sistemlerde yaygın olarak kullanılan Log4j kütüphanesinde uzaktan kod yürütme imkânı tanımış; Apple, Twitter, Steam ve Minecraft gibi büyük platformları doğrudan etkilemiştir.

Zafiyet taraması için endüstride yaygın olarak kullanılan araçlar arasında Nmap (port tarama standardı), Nikto (web sunucusu odaklı tarayıcı), OpenVAS ve Nessus (kurumsal seviye kapsamlı tarayıcılar) yer almaktadır. Bu araçların büyük çoğunluğu Kali Linux dağıtımında varsayılan olarak gelmektedir.

Yasal ve etik açıdan vurgulanması gereken önemli bir nokta vardır: tarama eylemi başlı başına bile, izinsiz gerçekleştirildiğinde pek çok yargı bölgesinde suç teşkil edebilmektedir. Bu nedenle zafiyet taramaları yalnızca kullanıcının kendi sistemleri üzerinde veya yazılı izin alınmış sistemlerde gerçekleştirilmelidir.

9. SQL INJECTION

SQL Injection (SQL enjeksiyonu), web uygulamalarına yönelik en eski ve en yaygın saldırı türlerinden biridir. OWASP (Open Web Application Security Project) tarafından periyodik olarak yayınlanan ve dünyanın en kritik web uygulama güvenlik risklerini sıralayan OWASP Top 10 listesinde yıllardır üst sıralarda yer almaktadır. İlk kez 1998 yılında tanımlanmış olmasına rağmen, üzerinden çeyrek asırdan fazla zaman geçmiş olmasına karşın hâlâ aktif bir tehdit olarak güncelliğini korumaktadır.

SQL Injection saldırısı, kullanıcıdan alınan girdinin yeterli filtreleme ve doğrulamadan geçirilmeden doğrudan SQL sorgusuna dahil edilmesi sonucu ortaya çıkar. Saldırgan, beklenen veri yerine SQL sözdiziminde özel anlam taşıyan karakterler içeren girdiler kullanarak sorgunun mantığını manipüle edebilmektedir.

Klasik bir saldırı örneği şu şekilde verilebilir. Bir kullanıcı giriş formunda kullanıcı adı alanına “admin' --” yazıldığında, arka planda çalışan SQL sorgusu “SELECT * FROM users WHERE username = 'admin' --' AND password = '...'” şeklini almaktadır. SQL dilinde iki tire (--) ile başlayan ifadeler yorum satırı olarak kabul edildiğinden, parola kontrolü tamamen devre dışı kalmakta ve saldırgan parolayı bilmeden admin yetkisiyle sisteme giriş yapabilmektedir. Bir başka klasik saldırı yöntemi olan tautolojik enjeksiyonda, “' OR '1'='1” girdisi kullanılarak sorgunun her zaman doğru sonuç vermesi sağlanır ve sistemdeki tüm kullanıcılar listelenir.

SQL Injection saldırılarının yıkıcı etkilerine en bilinen örneklerden biri 2017 yılında ABD’de yaşanan Equifax veri ihlalidir. Bu olayda, ülkenin önde gelen kredi puanlama kuruluşlarından birine yapılan saldırı sonucunda yaklaşık 147 milyon kişinin sosyal güvenlik numaraları, doğum tarihleri, ehliyet bilgileri ve kredi kart numaraları başta olmak üzere hassas verileri çalınmıştır.

SQL Injection saldırılarından korunmak için uygulanması gereken çeşitli savunma yaklaşımları bulunmaktadır. Birincisi ve en etkili olanı parametreli sorguların (prepared statements) kullanılmasıdır; bu yöntemde sorgu yapısı ve veri ayrı ayrı taşınır, kullanıcı girdisi hiçbir koşulda sorgunun yapısal parçası olamaz. İkincisi, modern ORM (Object-Relational Mapping) kütüphanelerinin (Prisma, SQLAlchemy, TypeORM vb.) tercih edilmesidir. Üçüncüsü, kullanıcı girdilerinin sıkı biçimde doğrulanması ve sterilize edilmesidir. Dördüncüsü, veri tabanına bağlanan uygulama hesabına en az yetki prensibinin uygulanmasıdır; bu sayede başarılı bir enjeksiyon dahi sınırlı zarar verebilir. Beşincisi, ek bir savunma katmanı olarak Web Application Firewall (WAF) kullanılmasıdır.

10. DEEP WEB VE TOR AĞI

İnternet, yaygın kabul gören sınıflandırmaya göre üç katmandan oluşmaktadır: Yüzey Web (Surface Web), Derin Web (Deep Web) ve Karanlık Web (Dark Web). Popüler kültürün etkisiyle bu kavramlar sıklıkla yanlış anlaşılmakta ve mistikleştirilmektedir; bu nedenle her bir katmanın net biçimde tanımlanması gerekmektedir.

Yüzey Web, Google, Bing gibi geleneksel arama motorları tarafından indekslenebilen, herkesin doğrudan erişebildiği internet katmanını ifade etmektedir. Wikipedia, YouTube, sosyal medya platformları, haber siteleri ve bloglar bu katmanda yer almaktadır. Yaygın bir yanılgının aksine, Yüzey Web aslında internetin yalnızca küçük bir bölümünü oluşturmaktadır.

Deep Web ise arama motorları tarafından indekslenmeyen ancak büyük çoğunluğu yasal ve sıradan içerikten oluşan internet katmanıdır. Bankacılık hesap sayfaları, e-posta gelen kutuları, kurumsal intranet sistemleri, üniversite öğrenci portalları ve akademik veri tabanlarının ücretli erişim arkasında kalan içerikleri Deep Web kapsamındadır. Bu içeriklerin “derin” olarak nitelendirilmesinin tek nedeni, kimlik doğrulama gerektirmeleri ve dolayısıyla arama motorlarının erişiminin dışında kalmalarıdır.

Dark Web, Deep Web’in özel bir alt kümesidir. Standart web tarayıcıları ile erişilemeyen ve özel anonimleştirme yazılımları gerektiren bu katmanın en yaygın erişim yolu Tor (The Onion

Router) projesidir. Tor, kullanıcı trafiğini en az üç farklı sunucu üzerinden geçirerek her aşamada bir kat şifreleme ekleyen, soğan kabuklarına benzer çok katmanlı bir yönlendirme protokolü kullanmaktadır. Bu yapı sayesinde tek bir sunucu, trafiğin tüm rotasını göremez ve kullanıcının anonimliği korunur. Dark Web'deki siteler ".onion" uzantısını kullanmaktadır.

Dark Web ile ilgili oldukça ilgi çekici bir gerçek, Facebook, BBC, New York Times ve ProPublica gibi büyük platformların resmi .onion adreslerine sahip olmalarıdır. Bu durum, baskıcı rejimlerin internet sansürü altındaki kullanıcılara erişim sağlamak amacıyla geliştirilmiş meşru bir uygulamadır. Aynı şekilde, gazetecilerin kaynaklarıyla anonim iletişim kurması için kullanılan SecureDrop platformu ve insan hakları örgütlerinin baskıcı koşullar altındaki muhabirlere ulaşması da Dark Web'in yasal kullanım örnekleri arasındadır.

Bununla birlikte Dark Web'in suç ekosistemleriyle de ilişkili olduğu yadsınamaz bir gerçektir. Uyuşturucu pazarları (örneğin 2013 yılında FBI tarafından kapatılan Silk Road), çalıntı veri ticareti ve diğer yasadışı faaliyetler bu katmanda yer alabilmektedir. Bu nedenle popüler kültürde sıkça yer alan "internetin %96'sı Dark Web'dir" veya "red room" hikayeleri büyük ölçüde abartılmış ya da uydurma içeriklerdir.

Türkiye'deki yasal duruma değinmek gerekirse, Tor yazılımının kullanılması başlı başına yasal bir eylemdir. Ancak Tor üzerinden gerçekleştirilen herhangi bir eylem yasadışı nitelik taşıyorsa, Tor yazılımı kullanıcıyı hukuki sorumluluktan korumaz. Yasadışı içeriği görüntülemek, indirmek veya paylaşmak hâlâ suç olarak değerlendirilmektedir. Buna karşılık, akademik araştırma, gazetecilik faaliyetleri ve dijital gizlilik amaçlı kullanım tamamen meşru kabul edilmektedir.

SONUÇ

Bu çalışma kapsamında siber güvenlik disiplininin temelini oluşturan on farklı konu incelenmiştir. Antik dönemden günümüze uzanan kriptografi tarihi, Sezar ve Vigenere gibi klasik algoritmaların basitliğinden başlayarak MD5 hash fonksiyonu ve RSA asimetrik şifreleme algoritması gibi modern matematiksel temellere oturmuş yapılara evrilmiştir. Şifreleme ile sık karıştırılan Base64 kodlama yöntemi de açıklığa kavuşturulmuş; her iki kavramın amaç ve kullanım alanları bakımından temel olarak farklı olduğu vurgulanmıştır.

Çalışmanın ikinci yarısında pratik siber güvenlik uygulamalarına geçilmiş; Kali Linux dağıtımının sanal makine üzerine kurulumu ve etik kullanım sınırları ele alınmıştır. Sonrasında ağ tabanlı DDoS saldırılarının teknik mekanizması, savunma altyapılarının zafiyetlerini ortaya çıkaran zafiyet tarama metodolojisi, web uygulamalarının baş belası SQL Injection saldırısı ve son olarak Deep Web ile Tor ağı kavramları açıklanmıştır.

Çalışmanın tamamı boyunca vurgulanan ortak bir mesaj bulunmaktadır: siber güvenlik yalnızca teknik bilgi değil, aynı zamanda etik sorumluluk gerektiren bir disiplindir. Bu alanda elde edilen bilgi ve beceriler, savunma amacıyla kullanıldığında bireyleri ve kurumları koruyabilecek değerli araçlardır; ancak kötü niyetli kullanım durumunda ciddi hukuki sonuçlar doğurabilirler. Bu nedenle

siber güvenlik öğrencileri ve uzmanlarının sürekli olarak yasal ve etik çerçeve içerisinde hareket etmesi büyük önem taşımaktadır.

Siber güvenlik alanı dinamik bir disiplindir; yeni saldırı teknikleri ve savunma yöntemleri sürekli olarak ortaya çıkmaktadır. Bu çalışmada ele alınan konuların her biri kendi başına çok daha derinlemesine incelenebilecek genişliktedir. Bu rapor, alan literatürüne giriş niteliğinde bir başvuru kaynağı olarak hazırlanmış olup, ilgili her başlığın akademik bilgi ile pratik uygulamayı bir araya getiren temel niteliğinde bir özet sunmayı amaçlamaktadır.

KAYNAKÇA

Anderson, R. (2020). Security Engineering: A Guide to Building Dependable Distributed Systems (3rd ed.). Wiley.

Diffie, W., & Hellman, M. (1976). New directions in cryptography. IEEE Transactions on Information Theory, 22(6), 644-654.

Kali Linux. (2026). Kali Linux Official Documentation. https://www.kali.org/docs/

OWASP Foundation. (2021). OWASP Top 10: 2021 The Ten Most Critical Web Application Security Risks. https://owasp.org/Top10/

Rivest, R., Shamir, A., & Adleman, L. (1978). A method for obtaining digital signatures and public-key cryptosystems. Communications of the ACM, 21(2), 120-126.

Stallings, W. (2017). Cryptography and Network Security: Principles and Practice (7th ed.). Pearson.

Tor Project. (2026). Tor Project: Anonymity Online. https://www.torproject.org/

Türkiye Cumhuriyeti. (2004). Türk Ceza Kanunu (Kanun No. 5237), Onuncu Bölüm: Bilişim Alanında Suçlar, Madde 243-245. Resmi Gazete.

Wang, X., & Yu, H. (2005). How to break MD5 and other hash functions. Advances in Cryptology – EUROCRYPT 2005, Lecture Notes in Computer Science, 3494, 19-35.

OWASP Foundation. (2023). SQL Injection Prevention Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html